

The seal of the University of Coimbra is a circular emblem. It features a central figure, likely a saint or scholar, seated and holding a book. The figure is surrounded by a decorative border containing the text 'CONIMBRIA' and 'SITATIS'. The seal is rendered in a light blue color.

Security Auditing

Lesson#2

Defining and planning an IT Security Audit

School Year 2024/2025

Master in Informatics Engineering (MEI)
Master in Informatics Security (MSI)

Informatics Engineering Department

University of Coimbra



Learning Objective

- Explain the **scope** of an IT audit for compliance and the use of standards and frameworks.
- Describe the components and basic requirements for creating an audit plan to support business and system considerations.

Key Concepts



THE BUSINESS CHALLENGES THAT EXIST IN COMPLIANCE



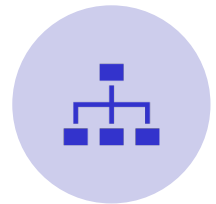
THE ISS DOMAINS THAT ARE AUDITED WITHIN AN IT INFRASTRUCTURE



THE ORGANIZATIONAL BARRIERS TO MAINTAINING IT COMPLIANCE



THE ORGANIZATIONAL INVOLVEMENT IN MAINTAINING IT COMPLIANCE



PROPER SECURITY CONTROLS, SUCH AS CONFIGURATION AND CHANGE MANAGEMENT



What Must Your Organization Do to Be in Compliance?

- Start with an organizational governance framework
 - Example: **ISO27k, NIST, COBIT, SANS**
- Implement **controls**
- Have **sound policies** in place
- Perform a **gap analysis**



Business Challenges to the Organization for Compliance

External

- Standards/**regulations change**
- Organizational **policies change**

Internal

- Standards can **interfere with operations**
- Gaining **internal acceptance** is challenging



Organizational Barriers to IT Compliance

- **Lack of alignment** to the business objectives and strategy
- General **misunderstanding** on the rationale for **IT compliance**
- **Funding** shortfalls
- **Lack of support** from top management
- **Misconception** of what the IT compliance will do for the organization



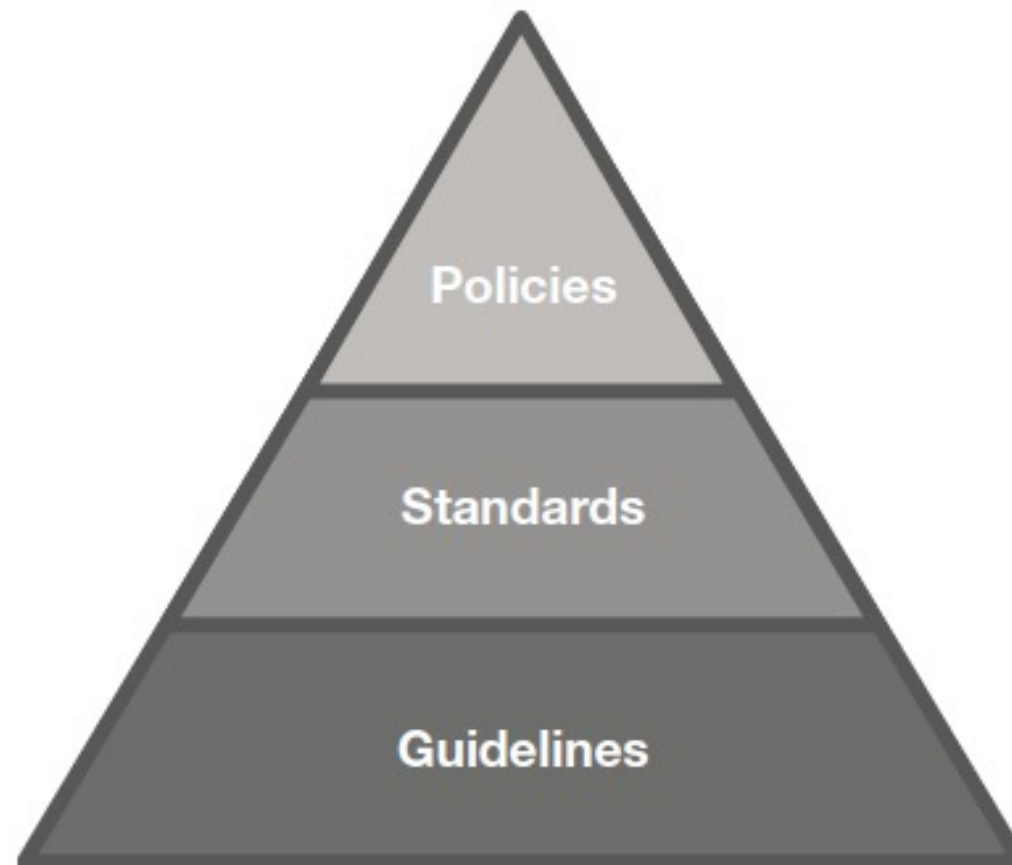
What Must Your Organization Do to Maintain IT Compliance?

Conduct **periodic security assessments**

Perform an **annual security compliance audit**

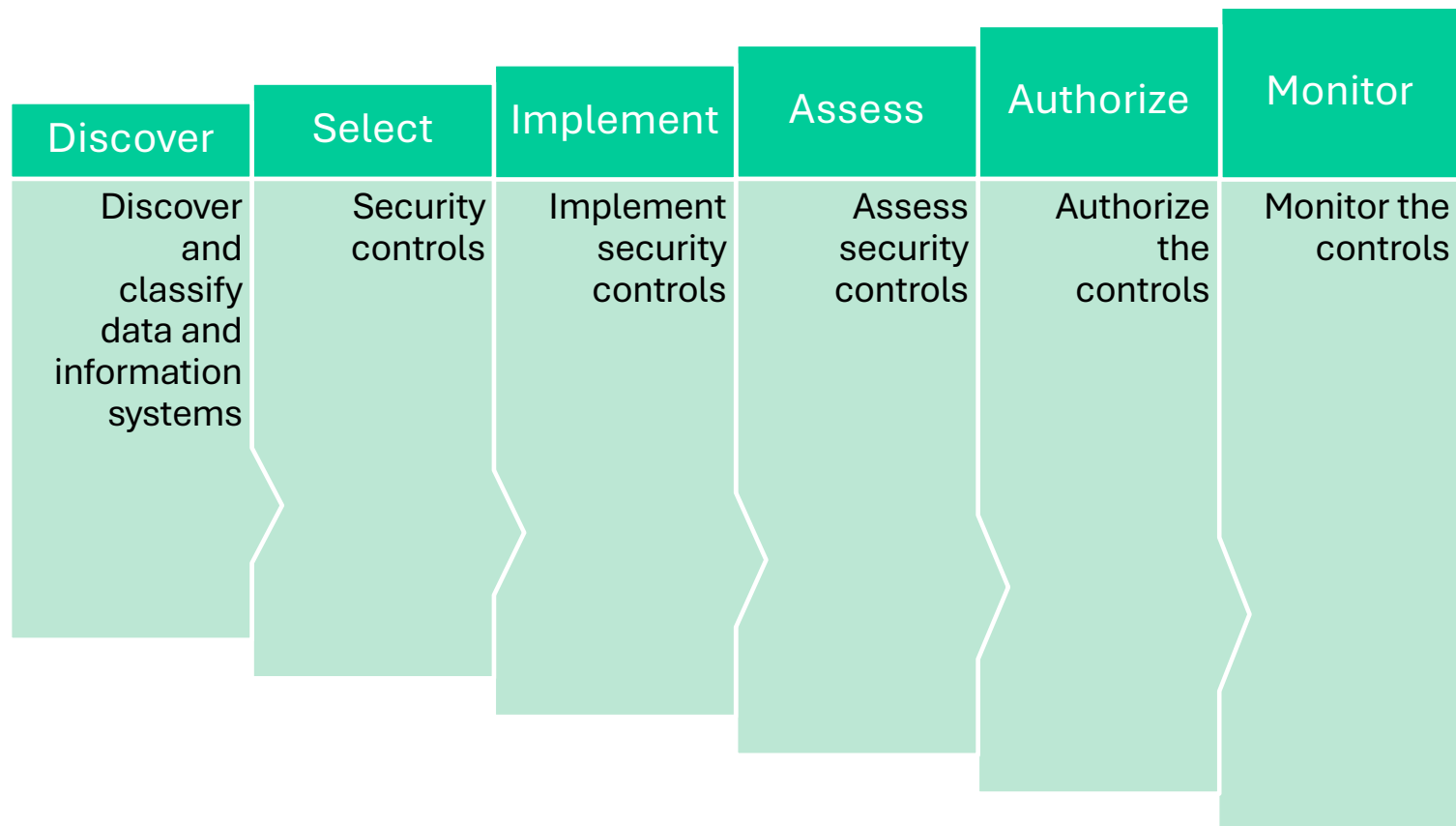
Define proper **security controls**

Creating an IT Security Policy Framework

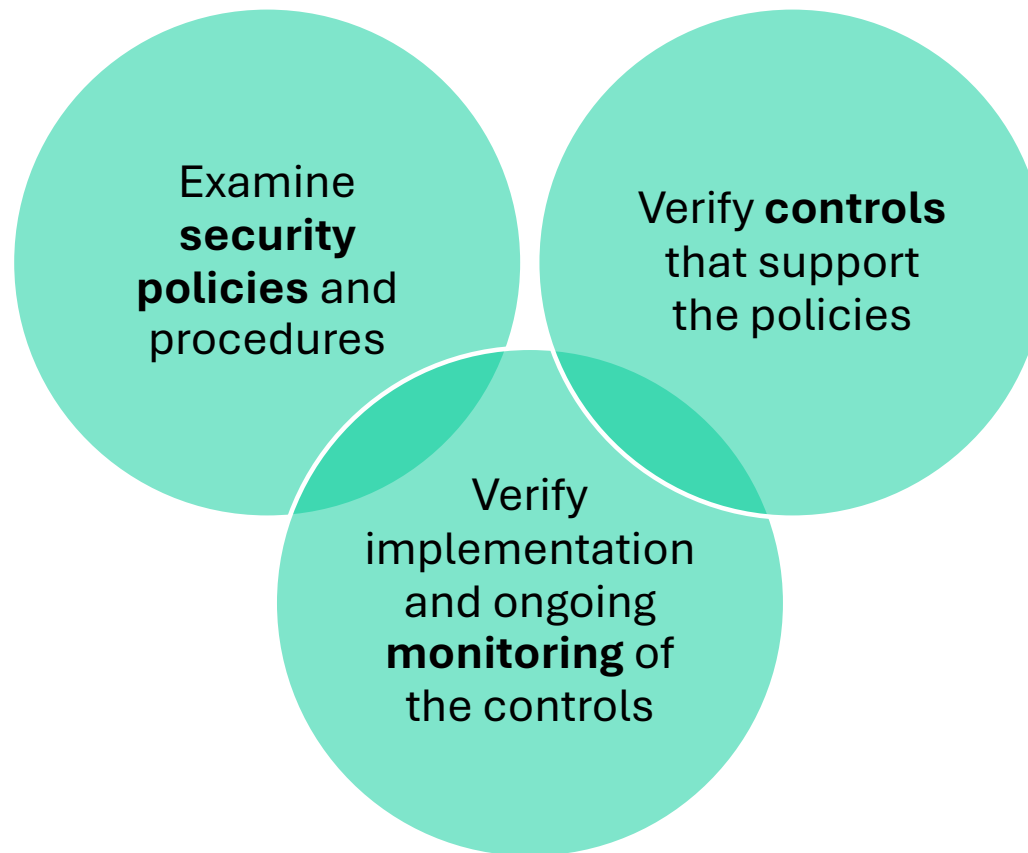




Designing and Implementing Security Controls



Domain Audit Objectives





Defining the Scope, Objectives, Goals, and Frequency of an Audit

Scope

- Includes area(s) to be reviewed and the time period

Goals

- Must be aligned with audit objectives

Objectives

- Should satisfy internal and external requirements

Frequency

- Every one, two, or three years



Scope Restrictions

Negative Impacts of Scope Restrictions

Not providing
enough
resources

Limiting the
time frame

Preventing the
discovery of
audit evidence

Restricting
audit
procedures

Withholding
relevant
historical
records or
information
about past
incidents



What Are You Auditing Within the IT Infrastructure?

- Examine the existence of relevant and appropriate **security policies** and **procedures**.
- Verify the existence of **controls** supporting the policies.
- Verify the effective **implementation and ongoing monitoring** of the controls.



Obtaining Information, Documentation, and Resources

Information spans many areas of an organization

Auditor

- Must understand organization
- Must understand security in place
- Must know industry best practices



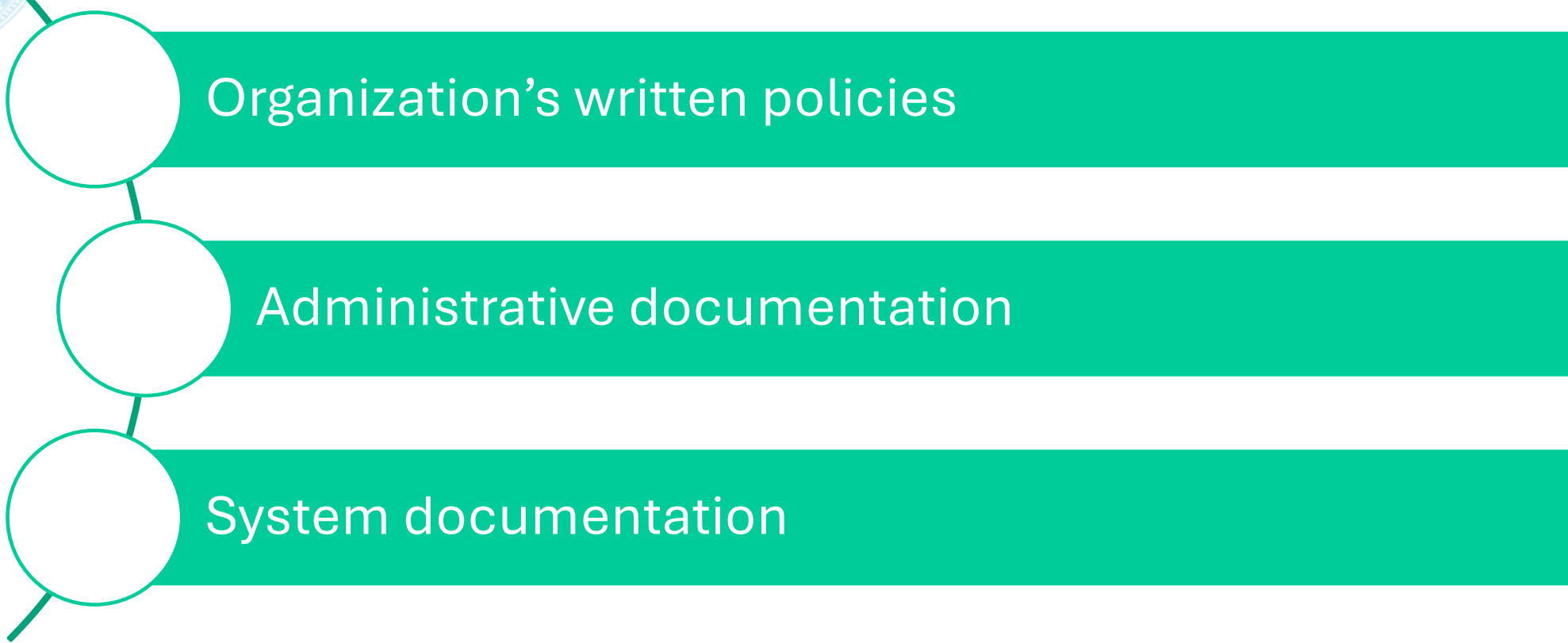
Information Gathering

Types of documentation:

- Administrative documentation
- System documentation
- Procedural documentation
- Network architecture diagrams
- Vendor support access documents and agreements



Necessary Documentation



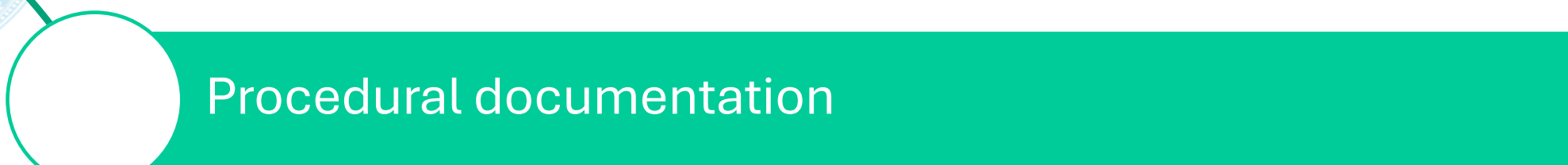
Organization's written policies

Administrative documentation

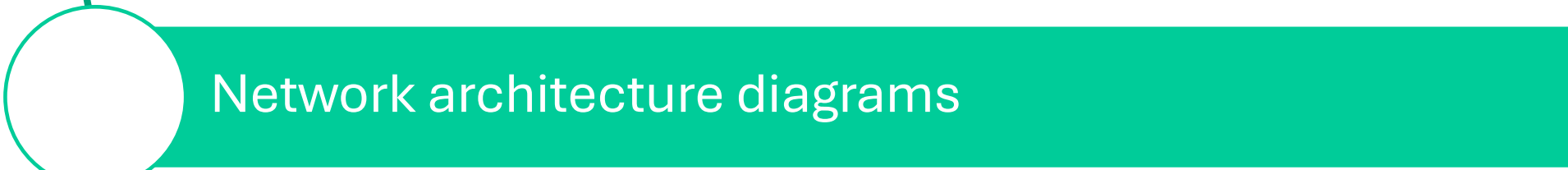
System documentation



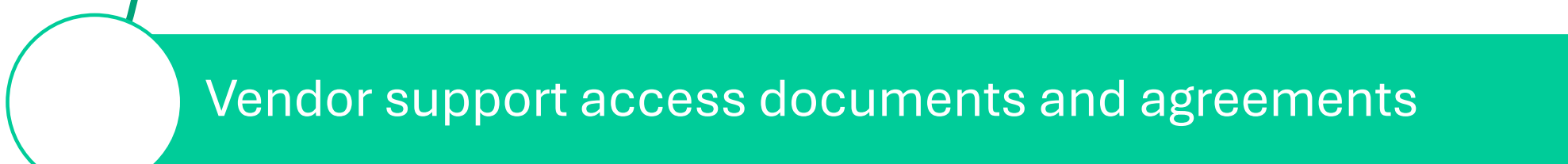
Necessary Documentation (Cont.)



Procedural documentation



Network architecture diagrams



Vendor support access documents and agreements

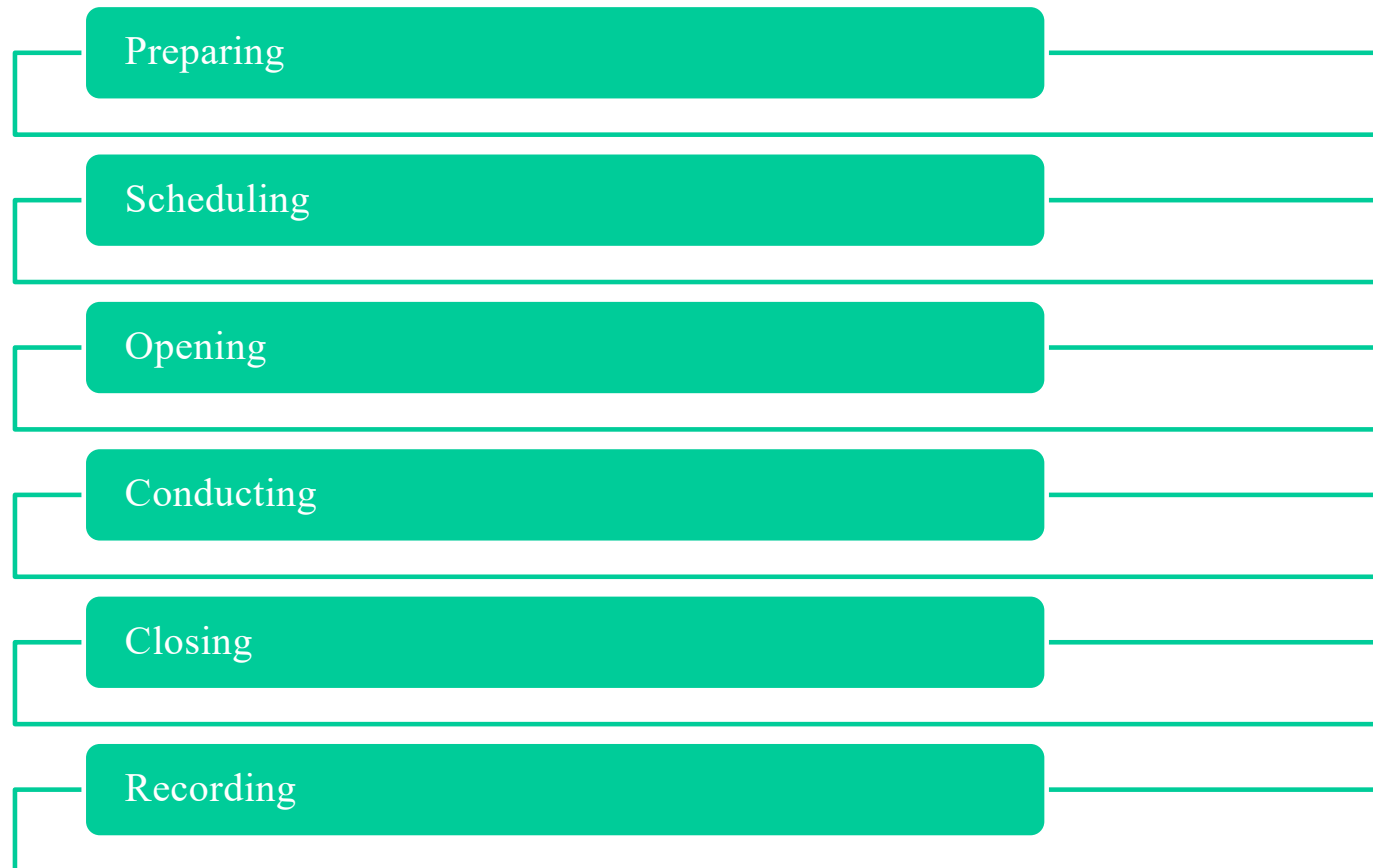


Existing IT Security Policy Framework Definition

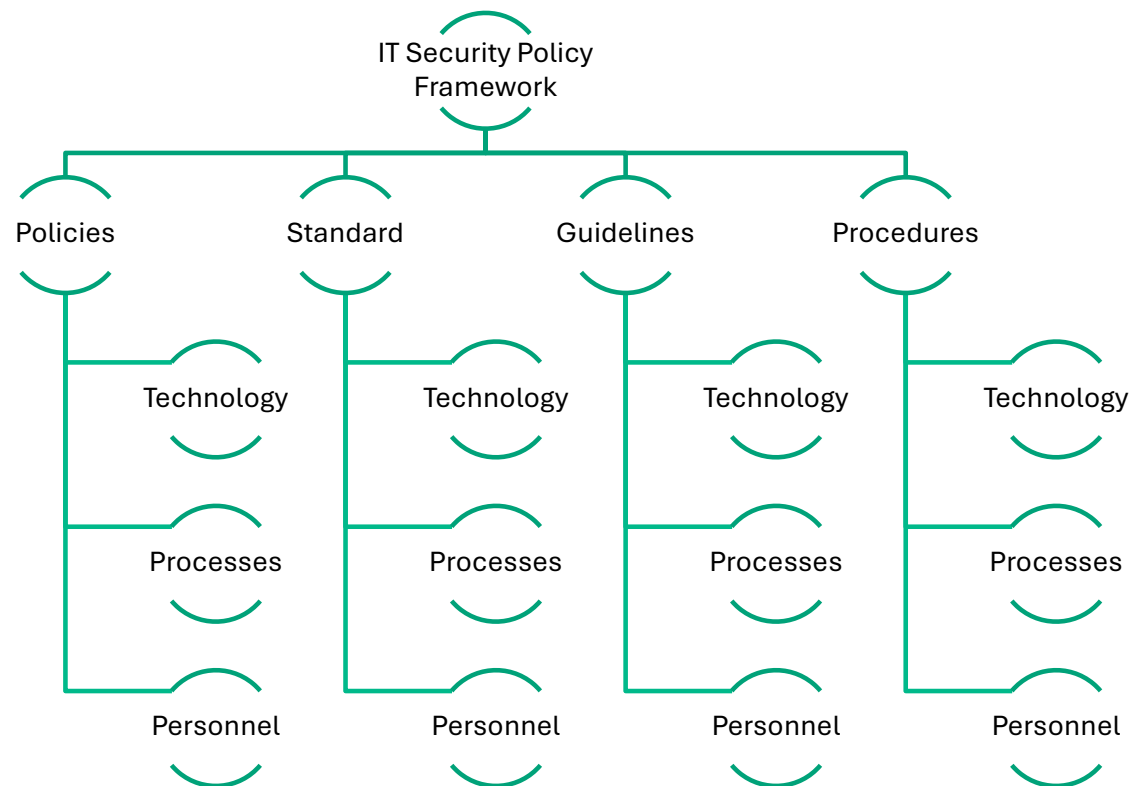
- Frameworks exist to help with risk management programs, security programs, and policy creation
- Ensure compliance across the IT infrastructure
- Important for the auditor to know upon what framework an organization has based its policy
- Allows better alignment between the organization's policy and the audit



Audit Interview Framework



Information Security Policy Audit Framework

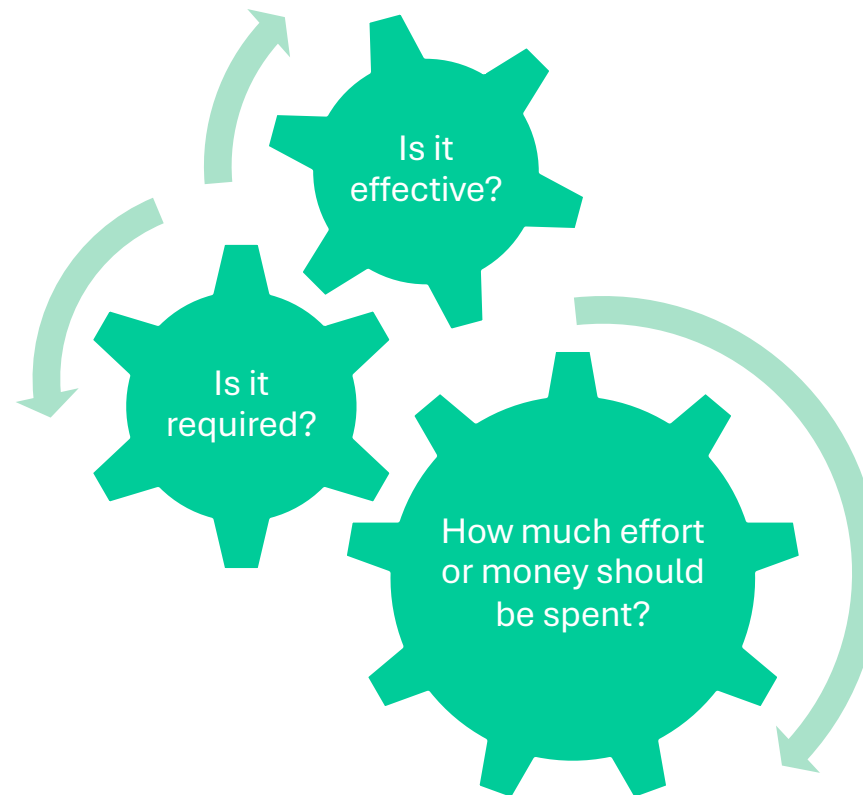




Information Security Policy Audit Framework (Continued)

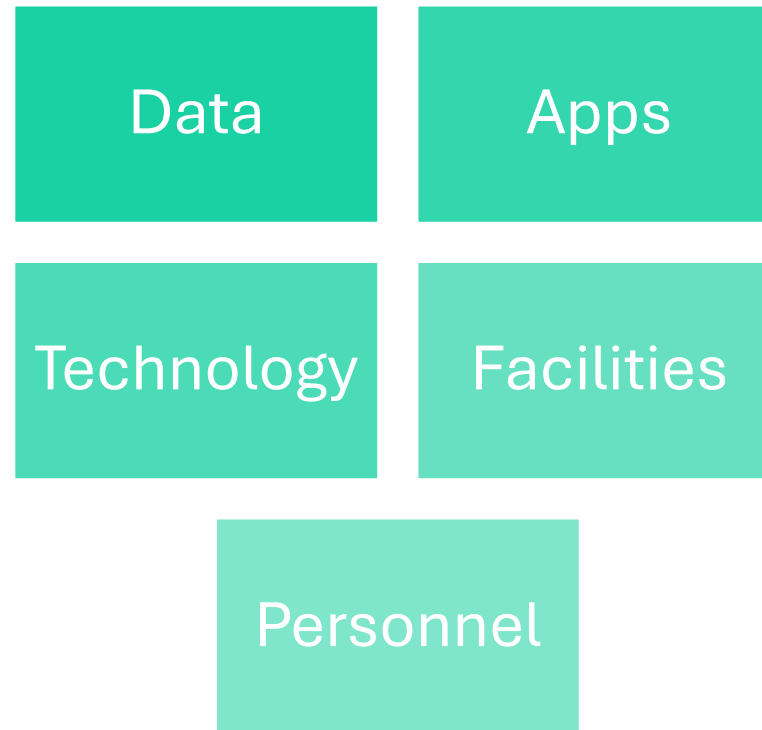
- Policies, standards, and guidelines may cross all domains of an IT infrastructure
- The **seven domains** map across various high-level areas:
 - Access control
 - Operations management
 - More

Assessing IT Security Controls

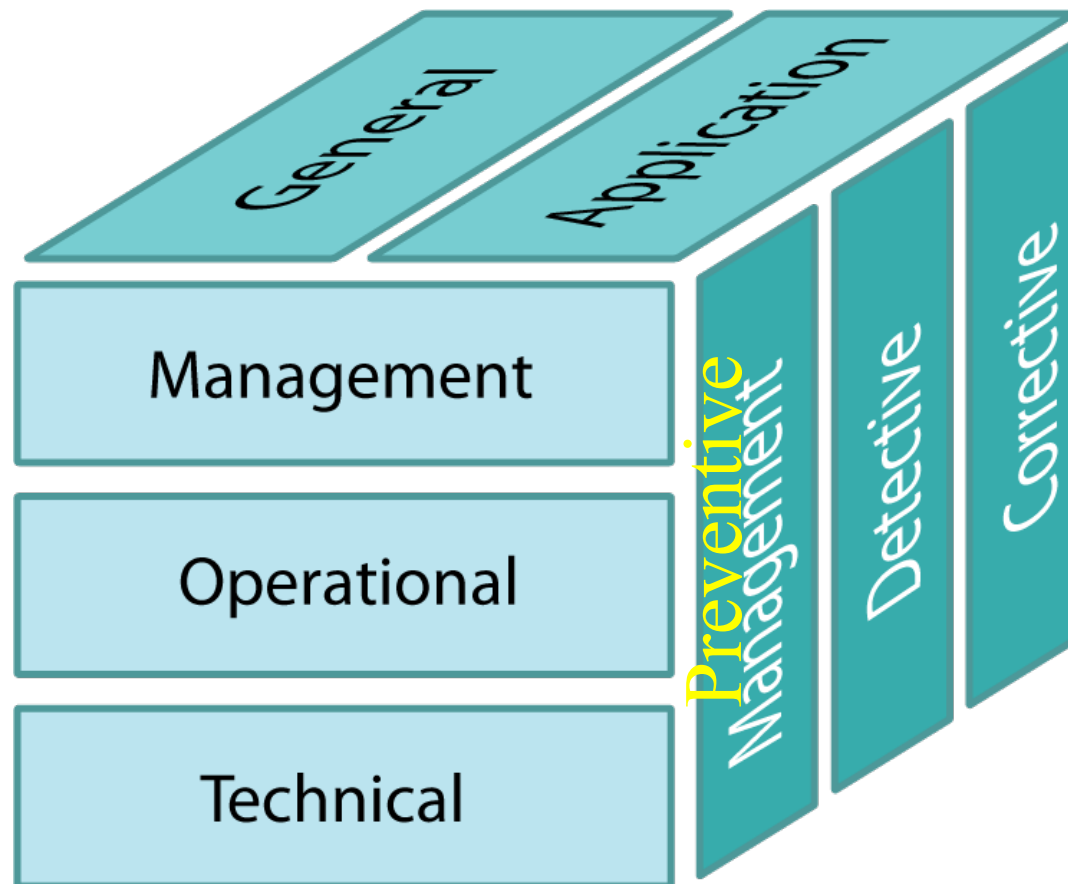




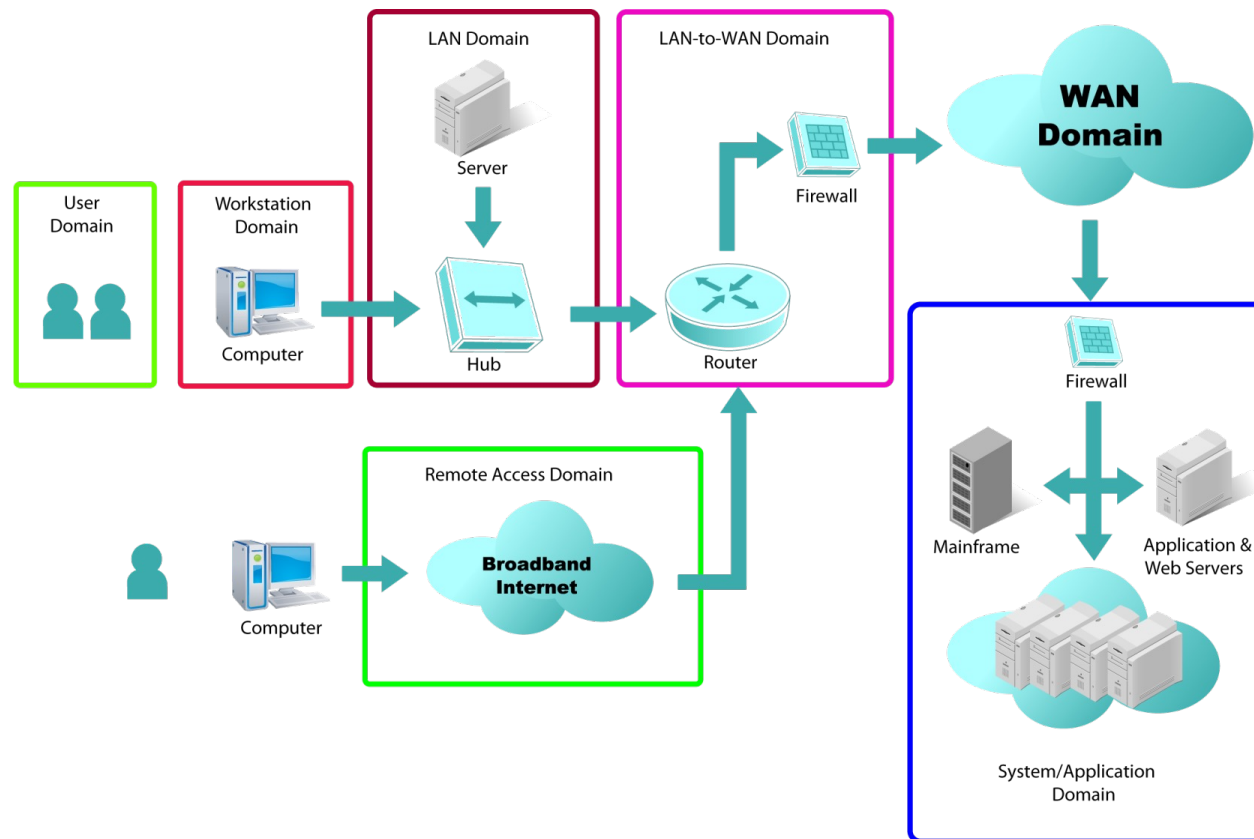
Resources in an IT Infrastructure



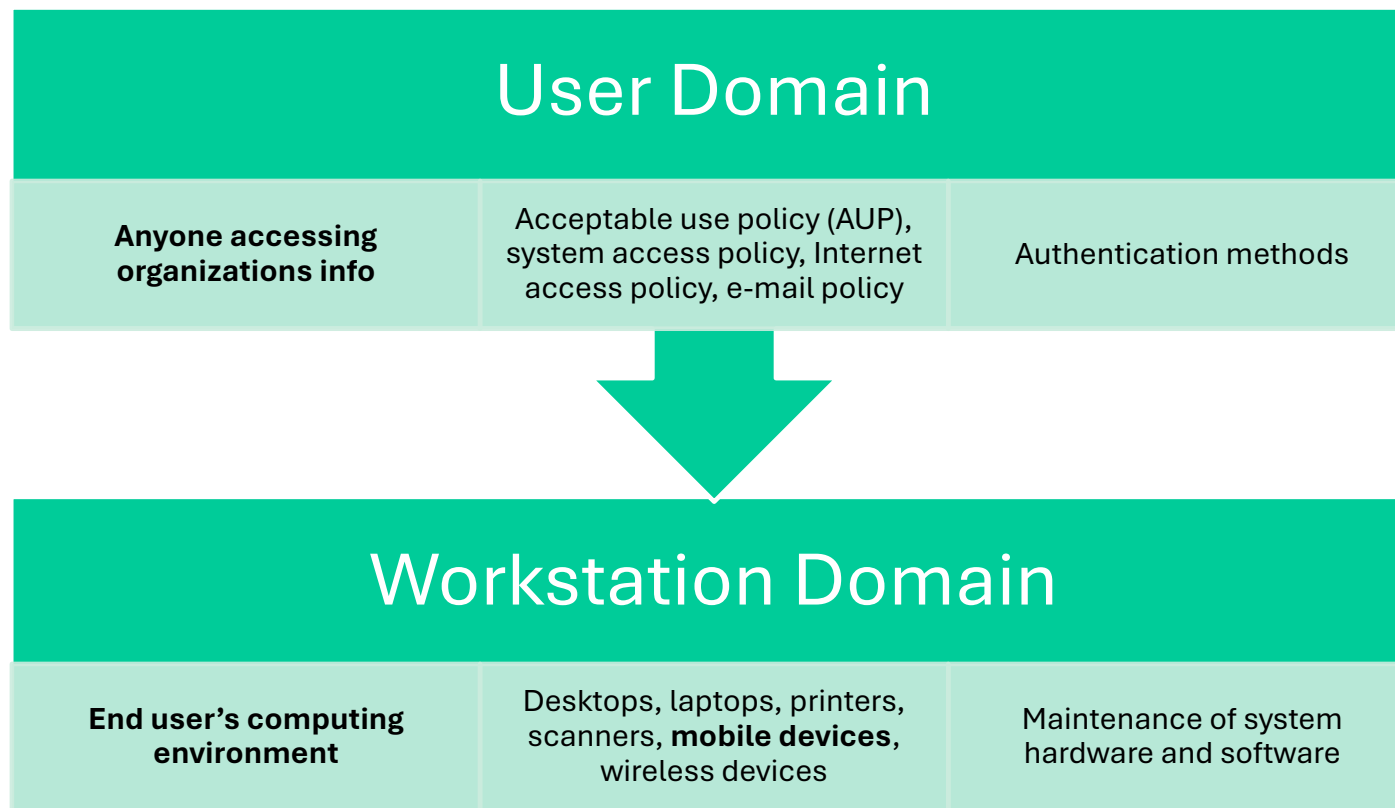
Security Control Points in an IT Infrastructure



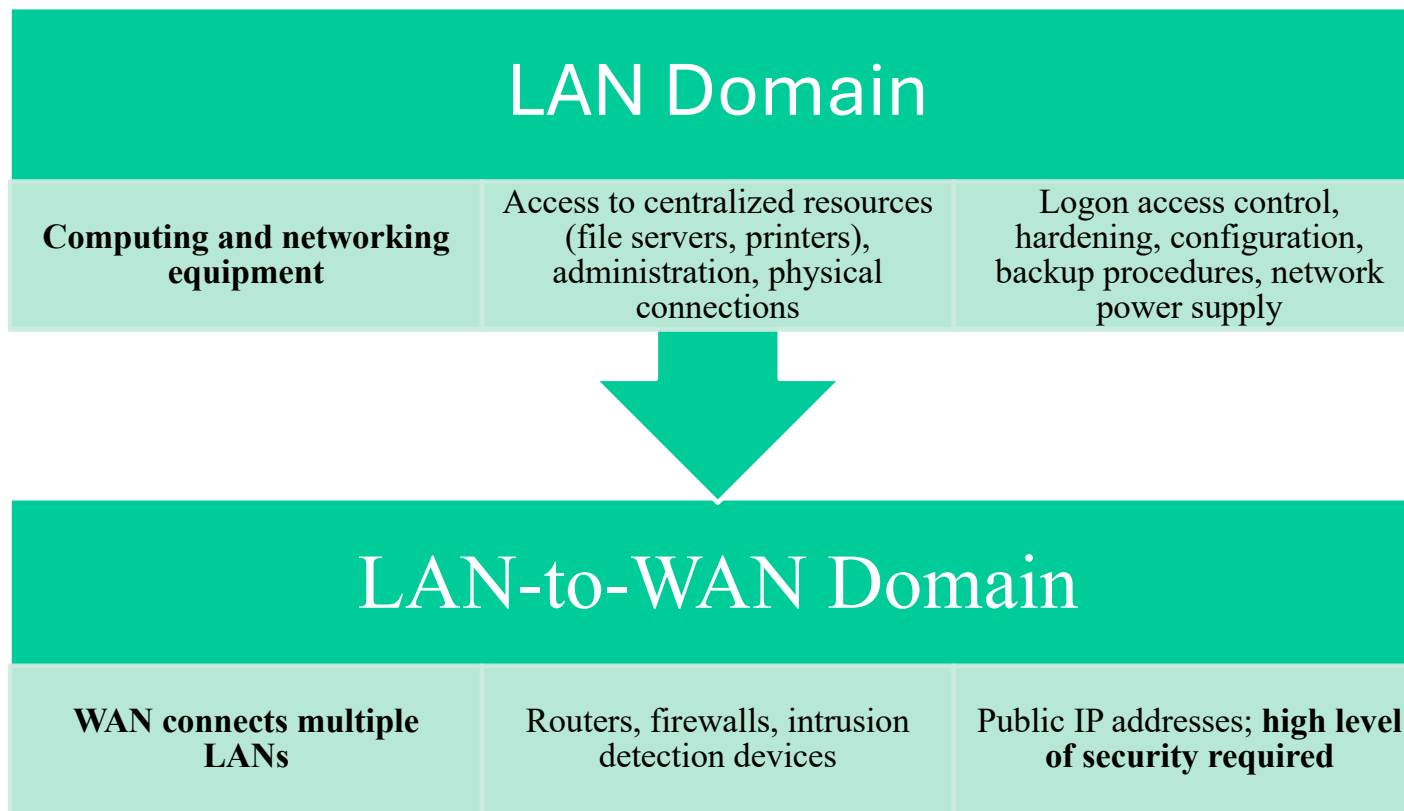
Seven Domains of a Typical IT Infrastructure



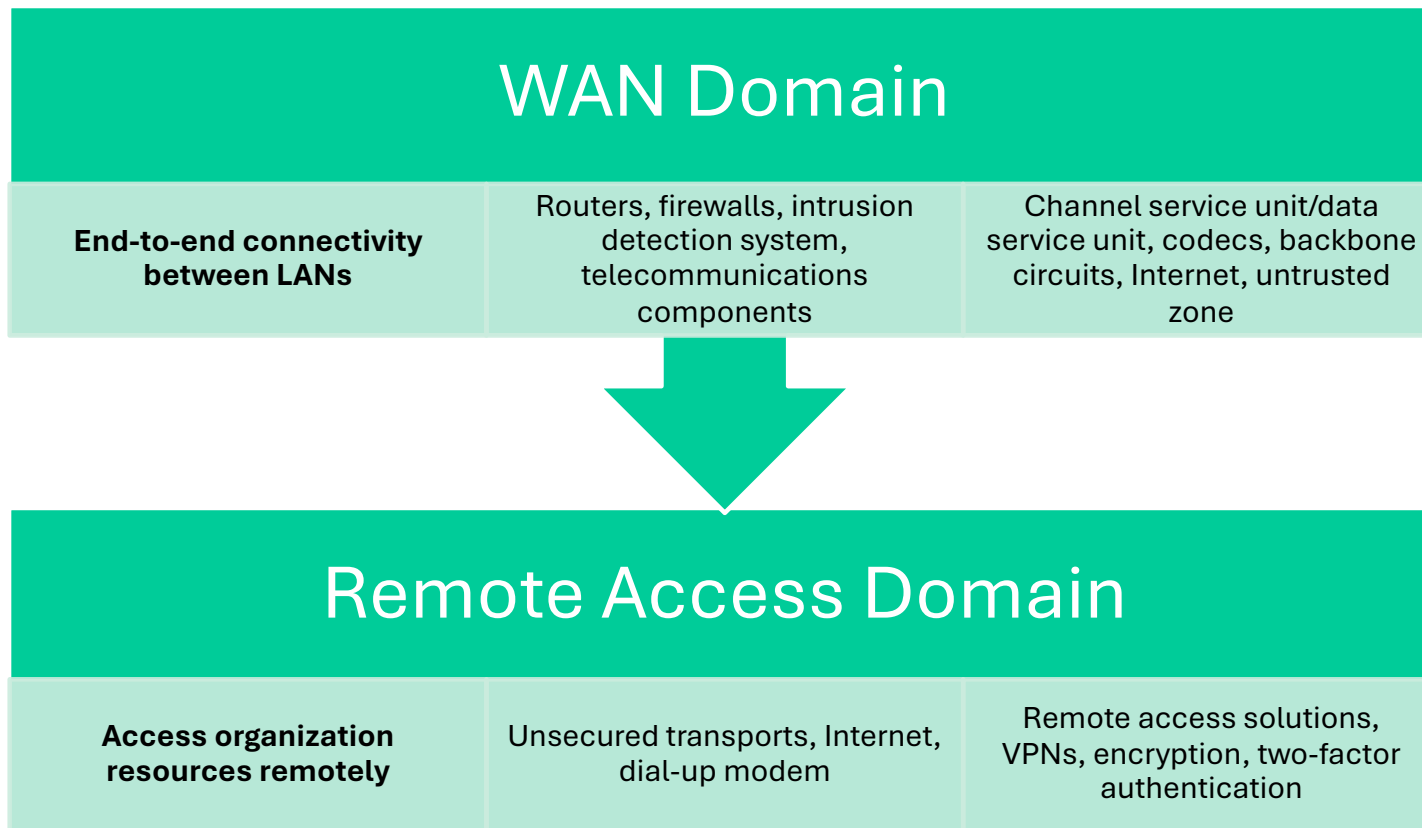
Auditing ISS Domains



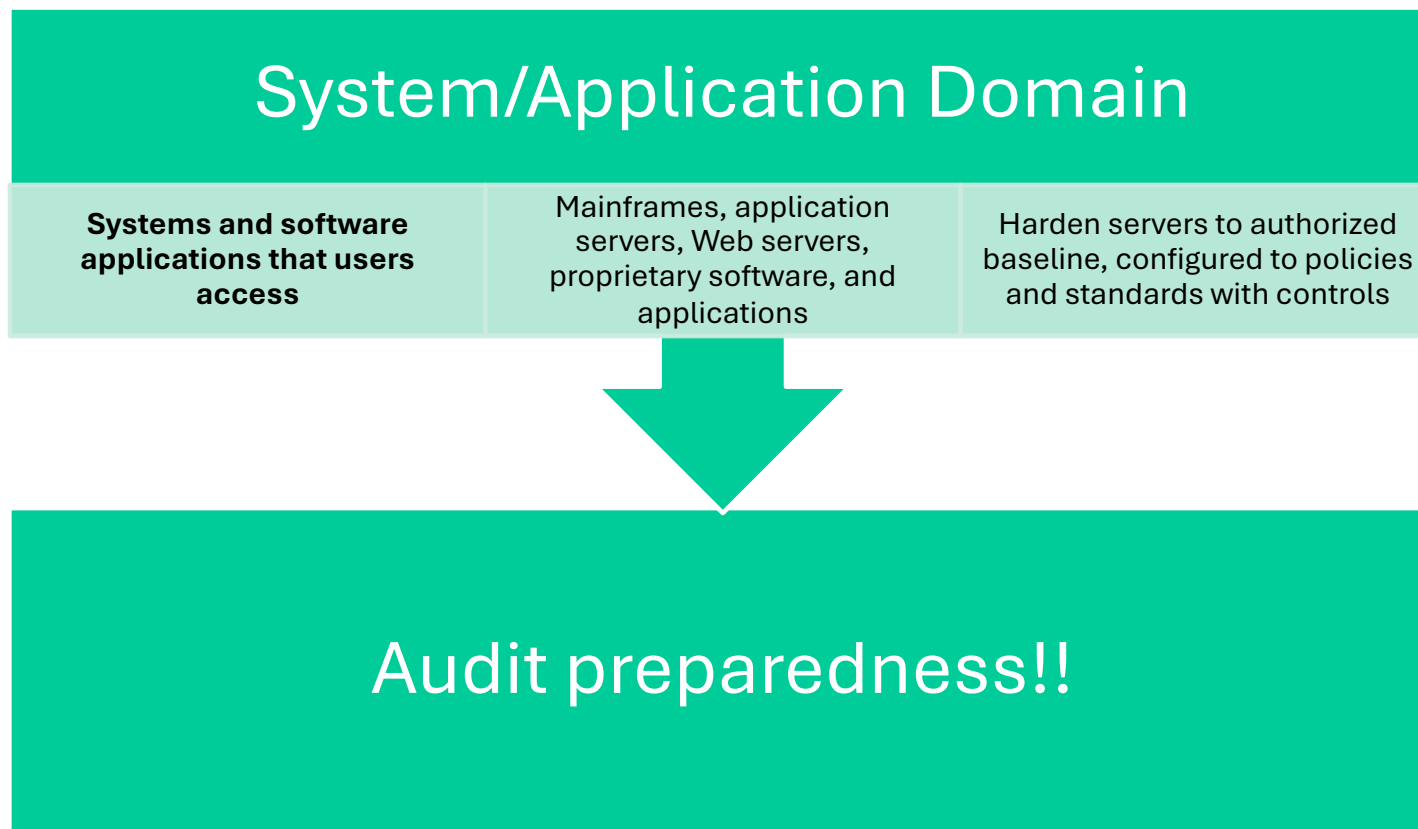
Auditing ISS Domains (*con't*)



Auditing ISS Domains (*con't*)



Auditing ISS Domains (*con't*)



Threat Analysis



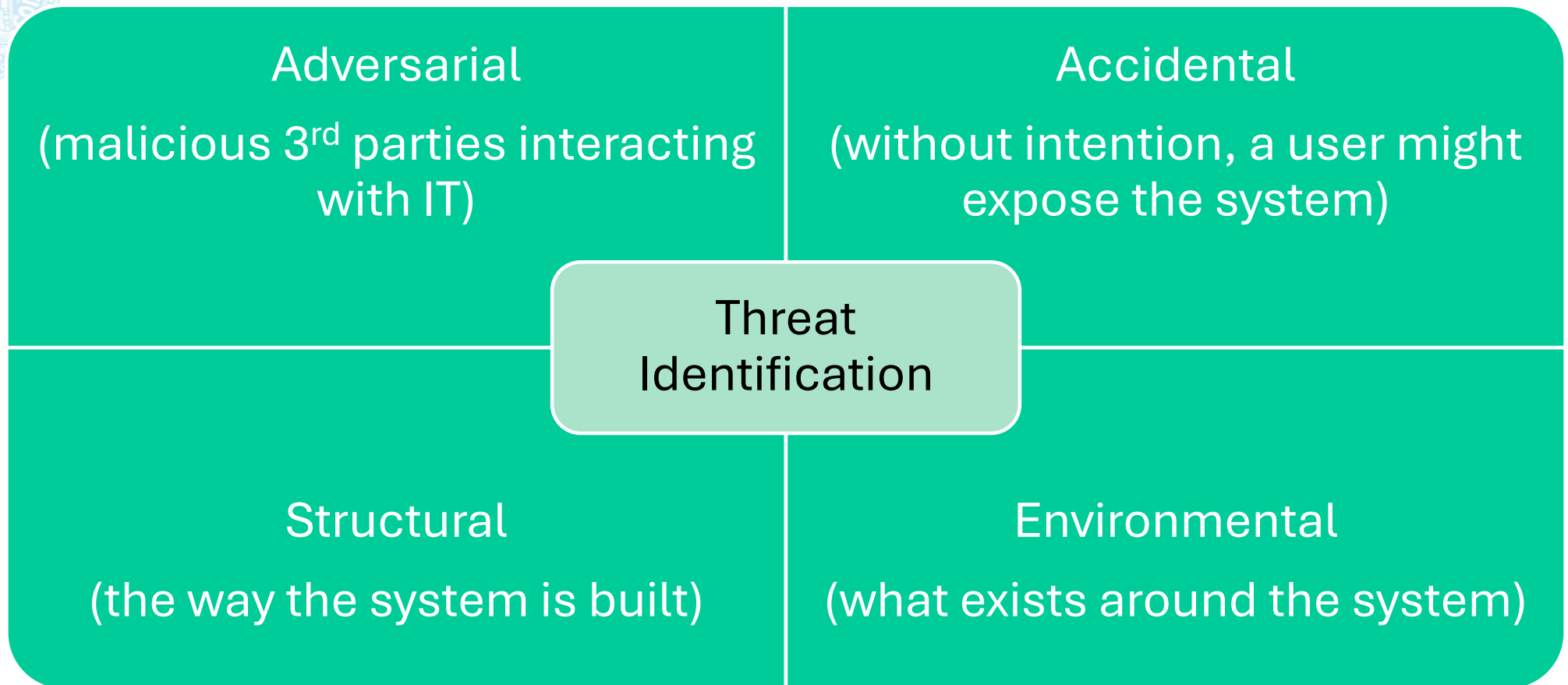
When undertaking a risk management plan, a complete threat analysis must be conducted.



Part of the risk assessment process requires an examination of those activities that represent danger.

Recommended reading: Schneier, Bruce; et al. (1998). ["Toward A Secure System Engineering Methodology"](#) (PDF). National Security Agency: Washington.

Threat Analysis (Continued)





Vulnerability Identification Resources

Vulnerability lists and databases

Security advisories

Software and security analysis



Security Controls, Configuration and Change Management

Security
Controls

Apply **across** the IT infrastructure

Configuration
Management

Ensures **changes** are requested,
evaluated, and authorized

Change
Management

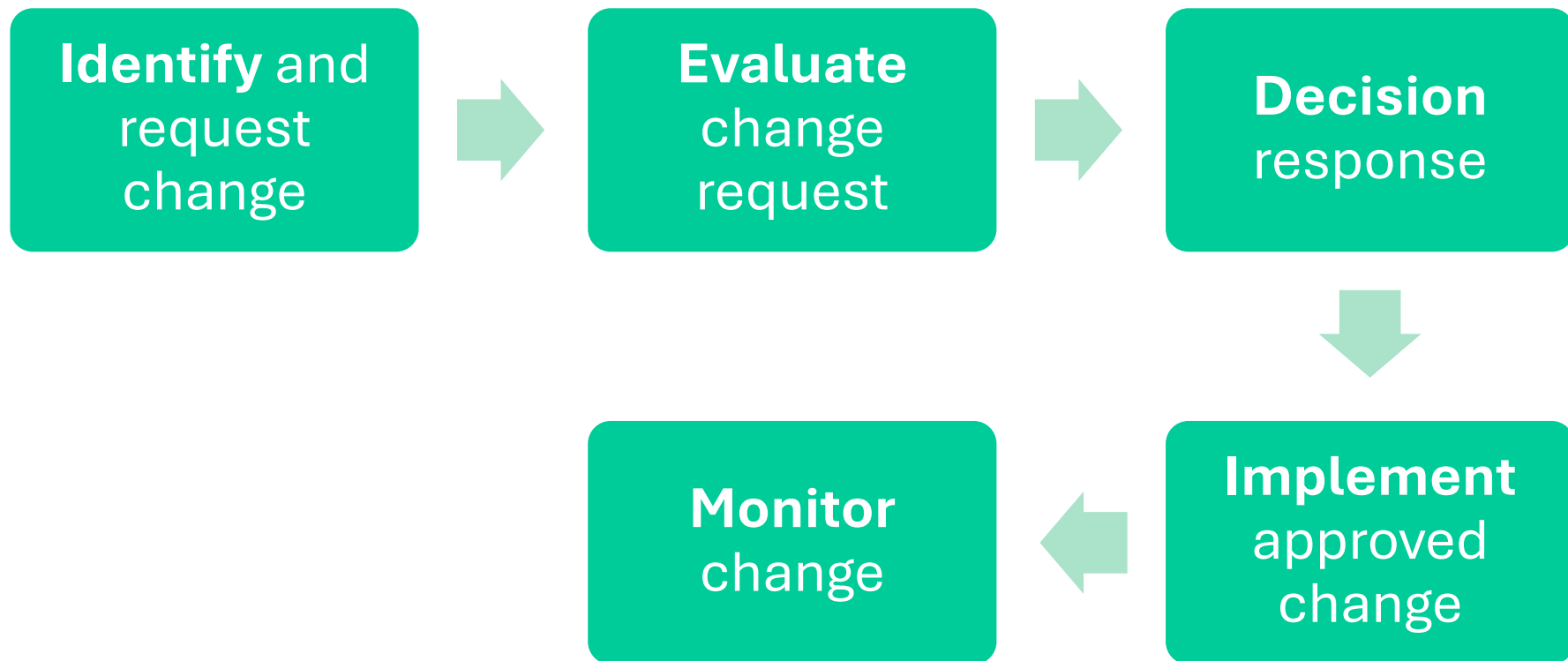
Provides method for **tracking**
unauthorized changes



Configuration and Change Management

- Process of **systems control throughout their life cycle**
- Making sure that systems are **operating correctly** and as intended in accordance with **security policies** and **standards**

Configuration and Change Management Process





Configuration Documentation

Examples of documents auditor should gather include:

- System configuration documentation
 - Internet Protocol (IP) addresses
 - Operating system
 - Patch level
 - Hardware specifications
 - Installed software
 - Protocols
 - Service configuration
 - User accounts
 - Password settings
 - Audit log settings
- Applications configuration documentation



Configuration Documentation (*Con't*)

- Network documentation for applications and systems being audited
- Standard **configuration documents** for role specific systems:
 - Firewalls
 - Web servers
 - Mail servers
 - Domain Name System (DNS) servers
 - File Transfer Protocol (FTP) servers



Privacy Management

Privacy Management – “The rights and obligations of individuals and organizations with respect to the collection, use, disclosure, and retention of personal information.”

Name

Personal
Identifiers

Address

E-mail

Physical
characteristics

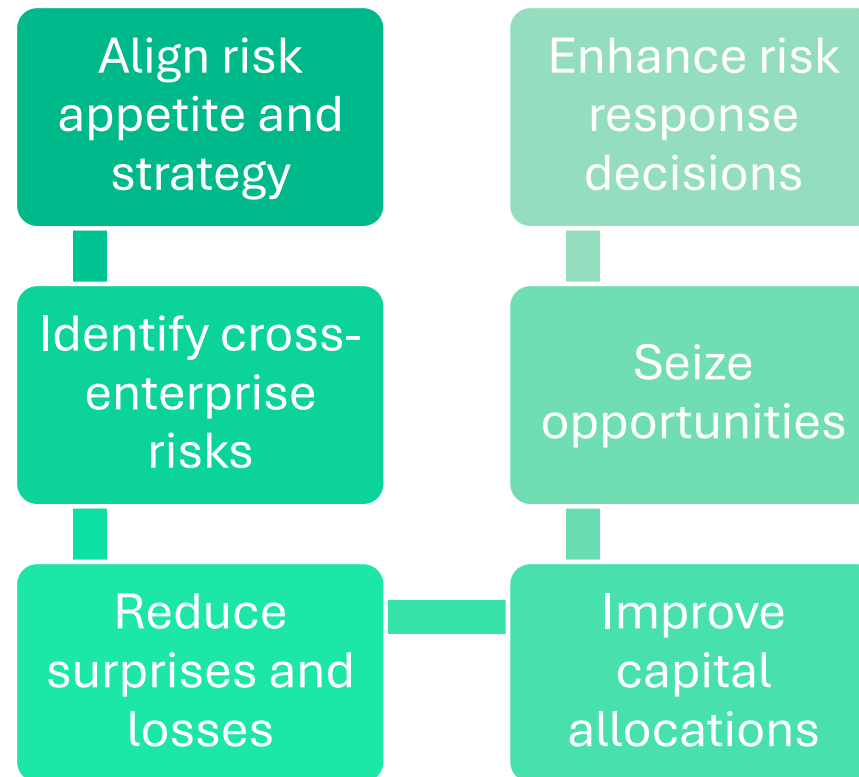


Protecting Privacy Data

- Develop appropriate **privacy policies**
- Establish a **privacy officer**
- Conduct **training and awareness** around data handling, identity theft, and social engineering
- Establish **data retention** and **data destruction** controls
- Conduct regular **risk assessments** of access controls
- **Limit data** to only that which is required
- Consider **security technologies (encryption)**
- US privacy laws and regulations: HIPAA, GLBA, COPPA, DNC Registry, and more..
- EU privacy laws and regulations: **GDPR**



Enterprise Risk Management (ERM)





Risk Assessment Analysis

Given the previous inputs, the final step is to determine the level of risk. When pairing threats and vulnerabilities, risk is determined primarily by three functions:

- The likelihood of a threat** to exploit a given vulnerability.
- The impact** on the organization if that threat against the vulnerability is achieved.
- The sufficiency of controls** to either eliminate or reduce the risk.



Risk Assessment Analysis (Continued)

There are always tradeoffs, and they include:

- Cost:** Are the costs of a control justified by the reduction of risk?
- Operational impact:** Does the control have an adverse effect on system performance?
- Feasibility:** Is the control technically feasible? Will the control be feasible for the end users?



IT Testing and Monitoring

- The most important and beneficial elements of an IT security program.
- **Testing and monitoring** must be conducted to know the controls are working.
- All frameworks include a control objective for **regularly assessing and monitoring** IT systems and controls.



IT Testing and Monitoring (Continued)

Questions that must be answered are:

- Is IT performance measured to **detect problems** before it is too late?
- Does management ensure that **internal controls are effective and efficient**?
- Can IT performance be **linked back to business goals**?
- Are adequate **confidentiality, integrity, and availability** controls in place for information security?



Identifying Critical Security Control Points

- Adequate controls should be in place to meet high-level defined control objectives
- Organizational risk assessment plays an important role in identifying high-risk areas
- Consensus Audit Guidelines (CAG)
 - Published by SANS
- Aka the SANS Top 20 Critical Security Controls



Tools Used in the IT Audit Process

- Electronic work papers
- Project management software
- Flowcharting software
- Open issue tracking software
- Audit department Web site
- Others



Summary

- The **business challenges** that exist in compliance
- The **ISS domains** that are audited within an IT infrastructure
- The **organizational barriers** to maintaining IT compliance
- The **organizational involvement** in maintaining IT compliance
- Proper **security controls**, such as **configuration and change management**
- Identifying **key building blocks** and critical requirements of an audit
- Identifying **critical security control points** and assessing information technology (IT) security
- Obtaining information through **documentation and resources**
- Organizing the **IT security policy**
- Analyzing best practices for testing and monitoring